

Day 24: Ransomware Detection and Response

Objective

The objective of this session is to understand how Security Operations Center (SOC) analysts detect, investigate, contain, and respond to ransomware attacks in enterprise environments.

By the end of this session, learners will be able to:

- Understand the concept of ransomware
- Identify common ransomware indicators
- Learn common ransomware attack methods
- Understand ransomware detection techniques
- Analyze ransomware investigation scenarios
- Learn incident response and containment procedures
- Understand SOC workflows during ransomware incidents
- Recommend prevention and recovery strategies

1. What is Ransomware?

Ransomware is a type of malicious software (malware) that encrypts files, systems, or entire networks and demands payment (ransom) from the victim in exchange for restoring access.

Attackers often demand payment in cryptocurrency such as Bitcoin to avoid detection.

Goals of Ransomware Attacks

Ransomware attackers aim to:

- Encrypt important files
- Disrupt business operations
- Steal sensitive data
- Demand ransom payments
- Pressure organizations using data leak threats

Common Targets

Ransomware commonly targets:

- Enterprises
- Hospitals
- Government agencies
- Financial institutions
- Educational organizations

Common Ransomware Families

Examples include:

- WannaCry
- LockBit
- Ryuk
- Conti
- BlackCat (ALPHV)

2. Common Indicators of Ransomware

SOC analysts monitor several indicators that may suggest ransomware activity.

1. File Encryption Activity

One of the most visible signs is sudden encryption of files.

Indicators

- File extensions suddenly change
- Files become inaccessible
- Large numbers of files modified rapidly
- Ransom notes appear on systems

Example

invoice.docx → invoice.locked

2. Suspicious PowerShell Activity

Attackers frequently use PowerShell to execute malicious commands.

Indicators

- Encoded PowerShell commands
- PowerShell downloading files
- Obfuscated scripts
- Execution from unusual locations

Example

```
powershell.exe -EncodedCommand <Base64_String>
```

3. Disabled Antivirus or Security Tools

Ransomware often disables security software before encryption begins.

Indicators

- Antivirus service stopped
- Endpoint protection disabled
- Logging services terminated

Why This Matters

Disabling protection helps attackers avoid detection.

4. Mass File Modifications

Ransomware rapidly modifies files across systems.

Indicators

- High file write activity
- Multiple file rename operations
- Sudden spikes in disk usage

Risk

This may indicate active encryption behavior.

3. Initial Access Methods

Attackers use multiple techniques to gain access before deploying ransomware.

1. Phishing Emails

Users receive malicious emails containing:

- Infected attachments
- Malicious links
- Fake login pages

Example

Urgent Invoice Attached

The attachment installs malware when opened.

2. Weak Passwords

Attackers exploit weak credentials through:

- Brute force attacks
- Password spraying
- Credential stuffing

Risk

Compromised accounts allow attackers to move inside the network.

3. Exposed RDP (Remote Desktop Protocol)

Publicly exposed RDP services are commonly targeted.

Attack Method

Attackers:

- Scan the internet for exposed RDP
- Attempt password attacks
- Gain remote access

Risk

RDP compromise is a major ransomware entry point.

4. Malicious Downloads

Users may unknowingly download infected software or cracked applications.

Examples

- Fake software installers
- Pirated applications
- Trojanized updates

4. Ransomware Detection Techniques

SOC teams use several techniques to identify ransomware activity early.

1. Monitor Abnormal File Activity

Security tools monitor for:

- Rapid file encryption
- Mass file changes
- Unusual file extensions

Example Detection Rule

```
IF modified_files > 1000 within 5 minutes  
THEN generate ransomware alert
```

2. Detect Encoded Commands

Encoded PowerShell commands often indicate malicious execution.

Detection Focus

- Base64 encoded commands
- Obfuscated scripts
- Suspicious child processes

3. Identify Backup Deletion Attempts

Attackers frequently delete backups before encryption.

Common Commands

```
vssadmin delete shadows
```

Why Attackers Do This

To prevent recovery from backups.

4. Monitor Privilege Escalation

Attackers may attempt:

- Admin privilege escalation
- Credential dumping

- Domain controller access before launching ransomware.

5. Investigation Example

Alert: Large number of files encrypted

Findings: Encoded PowerShell execution Backup services disabled

Analysis: Possible ransomware attack

Alert

Large number of files encrypted

Findings

- Encoded PowerShell execution detected
- Backup services disabled
- Suspicious outbound network connections
- Antivirus service terminated

Step-by-Step Investigation

Step 1: Review Endpoint Alerts

SOC analysts identify:

- Rapid file modifications
- Encryption behavior
- Suspicious process execution

Step 2: Analyze PowerShell Activity

Analysts review:

- Command execution history
- Encoded scripts
- Downloaded payloads

Finding

Malicious PowerShell commands were executed.

Step 3: Investigate Backup Activity

Analysts discover:

- Shadow copies deleted
- Backup services disabled

Security Interpretation

Attackers attempted to prevent recovery.

Step 4: Network Analysis

SOC teams analyze:

- External connections
- Lateral movement
- Communication with command-and-control servers

Analysis

Possible Ransomware Attack Detected

Risk Level

CRITICAL

6. Incident Response Process

SOC teams follow structured response procedures during ransomware incidents.

Step 1: Isolate endpoint

Step 2: Disable affected accounts

Step 3: Preserve evidence

Step 4: Begin recovery

Step 1: Isolate Endpoint

Immediately isolate infected systems from the network.

Purpose

- Prevent ransomware spread
- Stop lateral movement
- Protect unaffected systems

Actions

- Disconnect network access
- Quarantine endpoint
- Disable remote connections

Step 2: Disable Affected Accounts

Compromised accounts may be disabled temporarily.

Purpose

Prevent attacker access and privilege abuse.

Step 3: Preserve Evidence

SOC analysts preserve forensic evidence for investigation.

Evidence Includes

- System logs

- Memory dumps
- Malware samples
- Network captures

Importance

Evidence supports:

- Root cause analysis
- Legal investigations
- Threat intelligence

Step 4: Begin Recovery

Recovery activities begin after containment.

Recovery Steps

- Restore clean backups
- Rebuild affected systems
- Patch vulnerabilities
- Validate system integrity

7. SOC Workflow During Ransomware Incident

Endpoint Alert



SIEM Correlation



Detection



Containment



Recovery

Workflow Explanation

1. Endpoint Alert

EDR or antivirus tools detect suspicious activity.

Examples

- File encryption
- Malicious PowerShell execution
- Suspicious processes

2. SIEM Correlation

The SIEM correlates multiple events.

Correlated Events

- File encryption
- Backup deletion
- Suspicious login activity
- External connections

Result

High-severity ransomware alert generated.

3. Detection

SOC analysts confirm ransomware activity through:

- Log analysis
- Endpoint investigation
- Threat intelligence correlation

4. Containment

The SOC isolates infected systems and blocks attacker activity.

Actions

- Isolate endpoints
- Block malicious IPs
- Disable compromised accounts

5. Recovery

IT and SOC teams restore operations securely.

Activities

- Restore backups
- Validate systems
- Monitor for reinfection

8. SOC Team Responsibilities

L1 Analyst – Monitoring & Triage

Responsibilities:

- Monitor alerts
- Identify suspicious activity
- Escalate ransomware incidents

Examples:

- Reviewing SIEM alerts
- Monitoring EDR dashboards

L2 Analyst – Investigation & Containment

Responsibilities:

- Investigate ransomware behavior
- Analyze affected systems
- Perform containment actions

Examples:

- Log analysis
- Endpoint investigation
- Malware identification

L3 Analyst – Advanced Response & Engineering

Responsibilities:

- Threat hunting
- Detection engineering
- Advanced malware analysis
- Improve ransomware detections

Examples:

- YARA rule development
- Threat intelligence integration
- Advanced forensic analysis

9. Response & Mitigation Strategies

Immediate Response Actions

- Isolate infected systems
- Disable compromised accounts
- Block malicious IPs
- Stop malicious processes

Investigation

- Review endpoint logs
- Analyze PowerShell activity
- Check network traffic
- Identify attacker persistence

Containment

- Prevent lateral movement
- Restrict unauthorized access
- Quarantine affected systems

Recovery

- Restore backups
- Reset passwords
- Apply patches
- Validate system integrity

Prevention

Organizations should:

- Enable MFA
- Restrict RDP exposure
- Deploy EDR/XDR solutions
- Conduct phishing awareness training
- Maintain offline backups
- Regularly patch systems

Assignment

1. Explain Ransomware

Ransomware is malicious software that encrypts files or systems and demands payment for recovery. It is one of the most dangerous cyber threats affecting organizations today.

2. List Common Indicators

Common ransomware indicators include:

- File encryption
- Suspicious PowerShell activity
- Disabled antivirus
- Backup deletion attempts
- Mass file modifications
- Unusual outbound connections

3. Describe Response Steps

Step 1: Isolate Systems

Disconnect infected devices from the network.

Step 2: Disable Compromised Accounts

Prevent unauthorized access.

Step 3: Preserve Evidence

Collect logs, memory dumps, and forensic artifacts.

Step 4: Recover Systems

Restore backups and rebuild affected systems securely.

Summary

Ransomware is a major cybersecurity threat that can severely disrupt business operations and cause financial loss. SOC analysts play a critical role in detecting ransomware activity, investigating suspicious behavior, and coordinating containment and recovery efforts.

By using SIEM correlation, endpoint monitoring, threat intelligence, and incident response procedures, SOC teams can reduce the impact of ransomware attacks and improve organizational resilience.

Key Takeaway

Effective ransomware detection and response require strong monitoring, rapid containment, forensic investigation, and secure recovery processes. Modern SOC teams rely on SIEM, EDR, threat intelligence, and automation to identify ransomware attacks early and minimize damage to enterprise environments.